

Báo cáo thực hành: Triển khai DVWA trên Ubuntu

Thành viên nhóm : Phạm Văn Minh Tiến

Phạm Văn Khang

Nguyễn Thành Tài

Mục tiêu: Xây dựng môi trường DVWA để thực hành an toàn thông tin (lab Web Security)

1. Mục tiêu

Mục tiêu của bài thực hành là triển khai và cấu hình ứng dụng DVWA (Damn Vulnerable Web Application) trên môi trường Ubuntu (máy ảo) để phục vụ việc luyện tập khai thác lỗ hổng web bao gồm: cài đặt Apache, MariaDB, PHP; cấu hình DVWA; tạo tài khoản, và thiết lập mức bảo mật 'low' để thực hành.

2. Môi trường triển khai

Hạng mục	Chi tiết
Hệ điều hành	Ubuntu (VMware)
IP nội bộ VM	192.168.211.136
Web server	Apache2
Database	MariaDB 10.11.13
PHP	PHP 8.x

DVWA	Clone từ digininja/DVWA (GitHub)
------	----------------------------------

Tài khoản DVWA admin / 1 (đã đặt lại)

3. Các bước thực hiện (tóm tắt)

Bước 1 — Cài đặt gói cần thiết

sudo apt update && sudo apt install apache2 mariadb-server php php-mysqli php-gd libapache2-mod-php git -y. Khởi động và kiểm tra apache/mariadb: systemctl status apache2, systemctl status mariadb.

Bước 2 — Tải mã nguồn DVWA

cd /var/www/html && sudo git clone https://github.com/digininja/DVWA.git (nếu đã tồn tại, giữ hoặc xóa rồi clone lại).

Bước 3 — Tạo database và user

Tạo database dvwa và MySQL user: CREATE DATABASE dvwa; CREATE USER 'tai'@'localhost' IDENTIFIED BY '1'; GRANT ALL PRIVILEGES ON dvwa.* TO 'tai'@'localhost';

Bước 4 — Cấu hình DVWA

Sao chép file config mẫu /var/www/html/DVWA/config/config.inc.php.dist → config.inc.php và chỉnh: \$_DVWA['db_server']='127.0.0.1';
\$_DVWA['db_database']='dvwa'; \$_DVWA['db_user']='tai';
\$_DVWA['db_password']='1';

Bước 5 — Tạo bảng DVWA

Mở http://192.168.211.136/DVWA/setup.php → nhấn Create / Reset Database để tạo bảng.

Bước 6 — Đặt security level = low

Sửa `$_DVWA['default_security_level'] = 'low'` trong config hoặc chọn Low trong giao diện DVWA Security. Nếu session cũ giữ giá trị, hãy xóa cookie / dùng cửa sổ ẩn danh.

4. Kiểm tra & Kết quả

Sau khi thực hiện các bước, kết quả kiểm tra như sau:

- Apache: active (running)
- MariaDB: active (running)
- Database 'dvwa' tồn tại và user 'tai'@'localhost' có quyền
- DVWA truy cập được qua trình duyệt tại <http://192.168.211.136/DVWA>
- Tài khoản admin đã được đặt mật khẩu '1' (đã lưu dưới dạng MD5 trong DB)
- Mức bảo mật được đặt là 'low' để thuận tiện cho lab

5. Vấn đề gặp phải & Giải pháp

Trong quá trình cấu hình phát hiện một số vấn đề nhỏ:

1. File cấu hình config.inc.php chứa các dòng lỗi/rác (do thao tác sed trước đó) → Đã backup và sửa lại, xóa dòng thừa, chèn chính xác `$_DVWA['default_security_level']`.
2. Phải xóa cookie/session trên trình duyệt để thay đổi security level có hiệu lực.
3. Lưu ý: mật khẩu DB và admin quá yếu (chỉ dùng cho lab).

6. Lệnh kiểm tra nhanh

```
systemctl status apache2 --no-pager
```

```
systemctl status mariadb --no-pager
```

```
ip a | grep inet
```

```
sudo mysql -e "SHOW DATABASES LIKE 'dvwa';"
```

```
sudo mysql -e "SELECT User,Host FROM mysql.user WHERE User='tai';"
```

curl -I http://127.0.0.1

sudo tail -n 60 /var/log/apache2/error.log

7. Đề xuất mở rộng

- Tạo snapshot VM trước khi thực hành để dễ rollback.
- Giới hạn truy cập DVWA qua firewall (UFW) hoặc VPN cho lớp lab.
- Kết hợp công cụ Burp Suite / OWASP ZAP để phân tích request và phát triển bài tập.
- Sau khi hoàn thành lab, tăng dần mức security để luyện kỹ năng bypass.

8. Chứng minh & Ảnh chụp màn hình (placeholders)

· Vui lòng thay thế các placeholder bằng ảnh chụp thực tế:

1. [Screenshot_01_Apache_Default_Page.png] - Trang mặc định Apache hiển thị tại <http://192.168.211.136>
2. [Screenshot_02_DVWA_Login.png] - Giao diện đăng nhập DVWA (admin / 1)
3. [Screenshot_03_DVWA_Setup.png] - Kết quả Create/Reset Database (Database setup complete)
4. [Screenshot_04_DB_Tables.png] - Kết quả SHOW TABLES trong database dvwa

Ghi chú: Mật khẩu '1' và user 'tai' chỉ dùng trong môi trường lab. Khi đưa vào môi trường thật, cần đổi mật khẩu mạnh và vô hiệu hóa các site để bị tấn công.

BÁO CÁO KỸ THUẬT: Triển khai Nginx + ModSecurity + CrowdSec

Mục tiêu: Xây dựng hệ thống bảo mật đa tầng cho web server, sử dụng Nginx, ModSecurity và CrowdSec.

1. Mục tiêu

Mục tiêu của bài thực hành là triển khai và cấu hình bộ ba Nginx – ModSecurity – CrowdSec nhằm tăng cường khả năng phòng vệ của hệ thống web. Cụ thể, Nginx đóng vai trò làm reverse proxy; ModSecurity giúp phát hiện và ngăn chặn các lỗ hổng ứng dụng web (SQL Injection, XSS...); CrowdSec hỗ trợ giám sát, phân tích và tự động chặn IP độc hại theo cộng đồng.

2. Môi trường triển khai

Thành phần	Chi tiết
Hệ điều hành	Ubuntu Server (VMware)
Web Server	Nginx 1.24.x
Firewall	UFW + CrowdSec Firewall Bouncer
ModSecurity	phiên bản v3.0 (OWASP CRS 3.x)
CrowdSec	phiên bản 1.6+
Ứng dụng kiểm thử	DVWA (Damn Vulnerable Web Application)
IP nội bộ	192.168.211.136

3. Các bước thực hiện

Cài đặt Nginx và kiểm tra dịch vụ

```
sudo apt update && sudo apt install nginx -y
systemctl status nginx
Truy cập http://<IP> để xác minh Nginx hoạt động.
```

Cài đặt ModSecurity và OWASP CRS

```
sudo apt install libnginx-mod-security -y
sudo git clone https://github.com/coreruleset/coreruleset /etc/owasp-crs
Sao chép crs-setup.conf.example thành crs-setup.conf.
```

Kích hoạt ModSecurity trong cấu hình Nginx

Trong file cấu hình server block (vd: /etc/nginx/sites-available/dvwa):

```
modsecurity on;
modsecurity_rules_file /etc/nginx/modsec/main.conf;
```

Tùy chỉnh file cấu hình chính của ModSecurity

```
sudo nano /etc/nginx/modsec/main.conf
SecRuleEngine On
Include /etc/owasp-crs/crs-setup.conf
Include /etc/owasp-crs/rules/*.conf
```

Cài đặt CrowdSec và bouncers

```
curl -s
https://packagecloud.io/install/repositories/crowdsec/crowdsec/script.deb.sh |
sudo bash
sudo apt install crowdsec crowdsec-firewall-bouncer-iptables -y
sudo systemctl enable --now crowdsec crowdsec-firewall-bouncer
```

Kiểm thử hệ thống

Thực hiện tấn công SQLi/XSS trên DVWA.

Kiểm tra log tại /var/log/modsec_audit.log và cscli alerts list để xác nhận cảnh báo và IP bị chặn.

4. Kết quả quan sát

- ModSecurity phát hiện các yêu cầu chứa payload SQLi (rule ID 942100) và XSS (rule ID 941100).
- Các sự kiện được ghi nhận trong audit log và chuyển tới CrowdSec để phân tích.
- CrowdSec ghi nhận alert dạng 'http-sqli' và thực hiện block IP tấn công thông qua firewall bouncer.
- Các yêu cầu tiếp theo từ IP bị block nhận mã phản hồi 403/404.

5. Vấn đề gặp phải & cách khắc phục

1. ModSecurity ban đầu ở chế độ DetectionOnly nên không chặn — khắc phục bằng cách bật SecRuleEngine On.
2. Một số rule CRS gây false positive — tạm thời vô hiệu hóa bằng SecRuleRemoveById.
3. CrowdSec không nhận log do sai parser — thêm nginx parser bằng lệnh: `sudo cscli parsers install crowdsecurity/nginx`.
4. Bouncer chưa hoạt động — fix bằng `cscli bouncers add <name>` và reload service.

6. Đề xuất mở rộng

- Tích hợp ModSecurity với SIEM để phân tích log tập trung.
- Duy trì chế độ DetectionOnly ít nhất 2 ngày trước khi bật Blocking.
- Cập nhật OWASP CRS và CrowdSec Scenarios định kỳ.
- Kết hợp rate-limiting trong Nginx để giảm DDoS.
- Dùng snapshot VM định kỳ trước khi thay đổi rule.

7. Lệnh kiểm tra nhanh

systemctl status nginx --no-pager

sudo tail -n 50 /var/log/modsec_audit.log

sudo cscli alerts list

sudo cscli decisions list

sudo iptables -L -n

curl -I http://127.0.0.1

8. Kết luận

Hệ thống Nginx + ModSecurity + CrowdSec đã được triển khai thành công, giúp tạo lớp phòng thủ nhiều tầng cho ứng dụng web. ModSecurity chịu trách nhiệm phát hiện/chặn payload độc hại, CrowdSec cung cấp khả năng tự động phân tích và chặn IP xấu. Cấu trúc này dễ mở rộng và phù hợp cho mô hình lab, đào tạo hoặc môi trường tiền triển khai (pre-production).